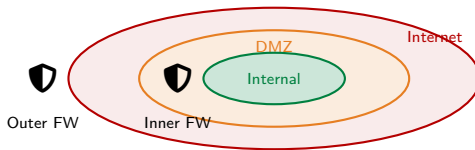


# Module 11: Zone-Based Security, IoT, and Physical Security

## Intro to Networks

Brendan Shea, PhD

Rochester Community and Technical College



# Outline I

- 1 Zone-Based Security
- 2 Internet of Things
- 3 Physical Security

# Review: Identity, Access, and Hardening

## Key Module 10 Ideas

- **AAA:** Authenticate who you are, authorize what you can do, and account for what you did.
- **RBAC and least privilege:** users and services should only have access to exactly what they need.
- **Hardening:** Remove defaults, disable unused services, patch regularly.
- **ACLs and firewalls:** Enforce traffic policy at network boundaries.

## Where Module 11 Takes This

Module 10 controlled *who* gets access. Module 11 controls *where* traffic is allowed to travel, how **physical zones** enforce security, and why devices like medical monitors and building sensors need special network treatment.

# Learning Outcomes I

After completing this module, you will be able to:

- Describe **network security zones** and explain why separating traffic by trust level reduces risk.
- Define the **screened subnet** (DMZ) and identify which services belong inside it.
- Explain the role of **perimeter networks** and how dual-firewall architectures differ from single-firewall designs.
- Identify common **IoT device** categories and explain why they present unique security challenges.
- Describe **industrial and embedded systems** and their constraints (long lifecycles, no patch support, safety-critical operation).
- Explain how to segment IoT devices onto isolated networks to limit their attack surface.
- Describe physical security controls: locks, access cards, mantraps, cameras, and motion sensors.
- Explain **geofencing** and how location-based policies complement network controls.

# Learning Outcomes II

- Apply defense-in-depth thinking across all three domains: logical zones, device segmentation, and physical access.

# 11.1 Zone-Based Security: The Big Idea

Not all traffic deserves equal trust. **Zone-based security** divides a network into distinct areas with defined trust levels, and enforces rules about which zones can talk to each other.

## Hospital Floor Analogy

Think about how a hospital manages access to different spaces:

- **Public lobby:** Anyone can walk in — untrusted, uncontrolled.
- **Emergency department:** Patients and staff only, ID required.
- **ICU:** Authorized clinical staff only, strict access log.
- **Operating theater:** Only the surgical team, sterile protocol.

Network zones work the same way. You do not give a visitor the same access as a surgeon.

## Why zones matter

If everything is on one flat network, a compromised device anywhere can reach everything everywhere. Zones **contain** breaches and **limit blast radius**.

# Network Security Zones

Most enterprise and healthcare networks organize traffic into at least three logical zones based on trust level.

## Untrusted (Internet)

The public internet. **Trust level: zero.** Traffic is assumed hostile until proven otherwise.

## Semi-Trusted (DMZ)

Services that must be reachable from the internet but should *not* have direct access to internal systems. Web servers, email gateways, patient portals.

## Trusted (Internal)

Workstations, EHR servers, file servers, medical devices. Should **never** be directly reachable from the internet.

## Medical IT: A Fourth Zone

Many healthcare environments add a dedicated **clinical/biomedical zone** for networked patient-care devices (infusion pumps, monitors, imaging). These devices often cannot be patched — isolating them limits exposure even if a workstation elsewhere is compromised.

# Zone Policies: What Is Allowed Between Zones?

Zones are only useful if you enforce policies at the boundaries. Default policy is **deny**; only explicitly permitted traffic passes.

| From          | To           | Typical Policy                                   |
|---------------|--------------|--------------------------------------------------|
| Internet      | DMZ          | Permit only: HTTP/S, SMTP (inbound mail)         |
| Internet      | Internal     | <b>Deny all</b> (no exceptions)                  |
| DMZ           | Internal     | Deny by default; permit only specific DB queries |
| Internal      | DMZ          | Permit outbound to published services            |
| Internal      | Internet     | Permit outbound; filtered by proxy               |
| Clinical zone | Internal EHR | Permit only EHR data flow ports                  |

## Key rule

Traffic from a *lower*-trust zone to a *higher*-trust zone must always be explicitly justified and tightly scoped. A DMZ web server should never freely connect to an internal file server.

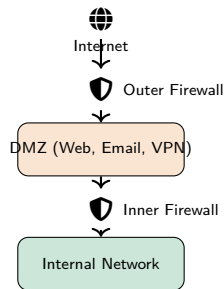


# Configuring a Screened Subnet

A **screened subnet** (also called a **DMZ** — demilitarized zone) is a network segment sandwiched between two firewalls: one facing the internet, one facing the internal network.

## Dual-Firewall Architecture

- 1 **Outer firewall:** Faces the internet. Allows inbound traffic only to services in the DMZ.
- 2 **DMZ:** Hosts services that must be reachable externally (web, email, VPN).
- 3 **Inner firewall:** Protects the internal network. DMZ hosts cannot initiate connections to internal servers unless explicitly permitted.



## Why two firewalls?

If the outer firewall is compromised, the inner firewall still protects internal systems. A single-firewall DMZ (three-legged) is cheaper but offers less isolation.

# Perimeter Networks

A **perimeter network** is the broader concept of a defended boundary between zones — the DMZ is its most common implementation.

## What Belongs on the Perimeter?

- **Web / application servers:** Serve external users.
- **Email gateway / spam filter:** Processes inbound mail before delivery.
- **VPN concentrator:** Terminates remote-access tunnels.
- **Reverse proxy:** Forwards external HTTP requests to internal app servers.
- **Patient portal servers:** Public-facing; must *not* share a segment with the EHR backend.

## What Does NOT Belong on the Perimeter?

- Internal file servers, AD domain controllers
- EHR / clinical databases
- Medical devices (infusion pumps, monitors)
- HR, payroll, financial systems

If a DMZ host is compromised, anything on the same segment is directly exposed.

# Screened Subnets: Design Choices

Organizations can implement screened subnets in several ways, each with trade-offs.

| Design                  | How It Works                       | Trade-off                                      |
|-------------------------|------------------------------------|------------------------------------------------|
| Single firewall (3-leg) | One FW with three interfaces       | Simple, lower cost; single point of failure    |
| Dual firewall           | Separate outer and inner firewalls | Stronger isolation; more complex to manage     |
| Multiple DMZs           | Separate DMZ per service category  | Fine-grained control; high management overhead |
| Cloud-hosted DMZ        | Cloud edge services (WAF, CDN)     | Scales easily; vendor dependency               |

## Medical IT Note: Multiple DMZs

A hospital might run separate screened subnets for: (1) the patient portal, (2) the lab-results interface for partner clinics, and (3) the telehealth platform. Each carries different risk — separating them limits what an attacker gains by compromising any one service.

# Case Study: Grey Sloan's Flat Network Disaster

## Scenario

Grey Sloan Memorial Hospital's IT team — overwhelmed after a merger with Mercy West — never completed the planned network redesign. Every device from the public check-in kiosks to the OR scheduling servers sits on a single flat 192.168.1.0/24 network.

On a Tuesday morning, ransomware spreads from a radiology workstation (running an unpatched OS required by legacy imaging software). Within four hours:

- The EHR system becomes unreachable, forcing staff to paper charts.
- The OR scheduling server is encrypted, causing elective surgery cancellations.
- The check-in kiosks display a ransom note to arriving patients.
- The PACS (medical imaging archive) is partially corrupted.

The workstation had not been patched in 18 months because the imaging vendor did not support the current OS.

## Discussion Questions

- 1 Which zone design failure most directly enabled the ransomware to spread this far?
- 2 Which systems should have been in a separate zone, even before the legacy workstation was patched?
- 3 What is the minimum segmentation design that would have contained the outbreak?

# Case Study Solution: Grey Sloan's Flat Network Disaster

## Recommended Response

- ① **Root cause:** A completely flat network with no zone boundaries. Once the radiology workstation was compromised, there was no firewall or VLAN boundary to slow lateral movement.
- ② **Zones that should have existed:**
  - *Clinical/biomedical zone:* Imaging workstations, PACS, OR scheduling.
  - *Patient-facing zone:* Check-in kiosks, guest Wi-Fi — isolated from clinical systems.
  - *Administrative zone:* EHR, HR, finance.
- ③ **Minimum containment:** Segment imaging into its own VLAN with a firewall rule permitting only specific PACS/DICOM ports to the EHR. Deny all other lateral traffic. The legacy workstation's blast radius becomes the imaging VLAN alone.

## Key Principle

A legacy device that cannot be patched is not automatically a catastrophe — but only if it is isolated. Segmentation is the compensating control when patching is not possible.

## 11.2 Internet of Things: What Is IoT?

**IoT** (Internet of Things) refers to physical devices — beyond traditional computers and phones — that connect to a network to send or receive data.

### IoT Devices in Everyday Life

- Smart thermostats, doorbells, TVs
- Fitness trackers, smartwatches
- Building systems: HVAC, lighting, badge readers
- Security cameras (IP cameras)
- Industrial sensors and control systems

### IoT Devices in Healthcare

- IV infusion pumps (smart drug delivery)
- Bedside monitors (HR, SpO<sub>2</sub>, BP)
- Networked ventilators
- MRI, CT, and X-ray machines
- Nurse call systems
- Automated medication dispensers

### Why Healthcare IoT Is Uniquely High Stakes

A compromised smart thermostat is an annoyance. A compromised infusion pump could affect patient safety. Network connectivity plus legacy software plus life-critical function makes medical IoT one of the most challenging security domains in IT.

# IoT in Everyday Life: Real Devices



**Amazon Echo (smart speaker)** — connects to cloud services for voice control of music, home automation, and shopping. Like all IoT devices, it is always-on and network-connected.

CC BY-SA 3.0, Frmorison / Wikimedia Commons



**Nest Learning Thermostat** — learns resident schedules and adjusts heating and cooling automatically via a cloud backend. A compromised thermostat can reveal occupancy patterns.

CC BY-SA 3.0, Amanitamano / Wikimedia Commons

# IoT in Healthcare: Real Devices



**Baxter Colleague CX infusion pump** — a networked IV pump that delivers precise drug doses. Drug libraries are updated over the network. Management interfaces have historically shipped with default credentials.

CC BY-SA 3.0/GFDL, © BrokenSphere / Wikimedia Commons



**ICU patient with bedside vital signs monitors** — these devices continuously transmit HR, SpO<sub>2</sub>, blood pressure, and waveform data to the nursing station. Isolation from general network traffic is essential.

CC BY-SA 4.0, Pittigrilli / Wikimedia Commons



# Why IoT Devices Are Hard to Secure

IoT devices break many assumptions that traditional IT security tools rely on.

| Traditional IT Assumption        | IoT Reality                                                           |
|----------------------------------|-----------------------------------------------------------------------|
| Software is patchable            | Many devices have no patch mechanism                                  |
| Devices run general-purpose OS   | Custom firmware, often years out of date                              |
| Admin can log in and configure   | No keyboard, no screen, no SSH access                                 |
| Default credentials are changed  | Frequently shipped with <code>admin/admin</code> or <code>1234</code> |
| Device lifecycle is 3–5 years    | Medical devices often used 10–20 years                                |
| Vendor provides security support | Vendor may be acquired, dissolved, or silent                          |

## The Infusion Pump Problem

A common IV pump may run firmware from 2011 on an embedded Linux kernel that has never been updated. The vendor's software approval process takes 18 months. By the time a patch is available, a new critical vulnerability has been found. The hospital cannot simply turn off the pump — patients need it.

# Industrial and Embedded Systems

**Embedded systems** are computing devices built into a larger piece of equipment, designed for a specific function rather than general-purpose computing.

## Medical Embedded Systems

- **PACS workstations:** Radiology image archive, often locked to a specific OS by the imaging vendor.
- **Lab analyzers:** Blood gas, chemistry, hematology. Network-connected to transmit results to EHR.
- **Physiologic monitors:** Bedside units collecting waveform data in real time.
- **Infusion pumps:** Drug library databases that must receive updates.

## General Industrial Embedded Systems

- **SCADA / ICS:** Supervisory control of power grids, water treatment, pipelines.
- **Building automation:** HVAC, elevators, fire suppression.
- **PLCs:** Programmable Logic Controllers in manufacturing.
- **Smart meters:** Utility monitoring with network backhaul.

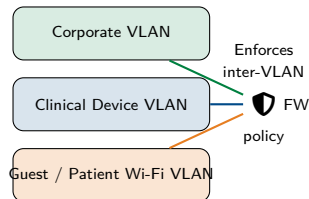
Both categories share the same fundamental problem: long lifespans, no patch cycle, and high consequence of failure.

# IoT Network Design: Isolation Is the Key Control

Because IoT and embedded devices often *cannot* be patched, network isolation is the primary compensating control.

## IoT Segmentation Best Practices

- 1 **Dedicated VLAN:** Put IoT devices on their own isolated VLAN(s), separate from user workstations.
- 2 **Firewall at the boundary:** Permit only the ports the device legitimately needs. Deny everything else.
- 3 **No direct internet access:** Route updates through an internal management server.
- 4 **Inventory everything:** You cannot protect what you do not know exists. Maintain a complete asset list.



# IoT Security: The Default Credential Problem

One of the most common and preventable IoT failures is leaving factory-default credentials in place.

## Why Default Credentials Are Dangerous

Many IoT devices ship with credentials like `admin/admin` or model-specific defaults published in vendor documentation and indexed by search engines. Attackers scan for these devices continuously.

## The IoT Security Checklist

- Change all default credentials immediately on deployment.
- Disable remote management interfaces if not needed.
- Disable unused protocols (Telnet, FTP, UPnP).
- Register devices for firmware update notifications.
- Document the device's required ports in a firewall rule.

## Shodan and the Open Hospital

Shodan is a search engine for internet-connected devices. Security researchers have found networked medical devices — including DICOM imaging servers and patient monitors — directly accessible on the public internet with default credentials. These were not targeted attacks; they were opportunistic discoveries anyone could make with a free account.

# Case Study: County General's Medical Device Mayhem

## Scenario

County General (the “Pit”) deployed 40 networked IV infusion pumps on its medical/surgical floor. Biomedical engineering, short-staffed after budget cuts, plugged the pumps into the existing staff workstation network jacks because the dedicated clinical VLAN rollout had been delayed. Temporary solution, they said.

Six months later, a nurse named Carol clicks a phishing link. Malware installs a network scanner and probes adjacent hosts. The infusion pump management interface — reachable on the same VLAN — responds on port 80 using the vendor default password `Hospira123`.

The IDS fires an alert three days later detecting unusual pump configuration changes originating from Carol's workstation IP.

- The pumps have no audit log of configuration changes.
- Firmware updates require a biomedical engineer to visit each pump physically.
- The “temporary” VLAN fix was never scheduled.

## Discussion Questions

- 1 Which two network design failures most directly enabled this incident?
- 2 What is the immediate containment action (without turning off the pumps)?
- 3 What organizational process failure allowed the “temporary” solution to persist six months?

# Case Study Solution: County General's Medical Device Mayhem

## Recommended Response

- ❶ **Two root failures:** (a) No VLAN isolation — clinical devices on the same segment as user workstations. (b) Default credentials not changed — the pump management interface was accessible with the published factory password.
- ❷ **Immediate containment:** Create an emergency ACL or VLAN change to block workstation traffic to pump management ports (80/443 on pump subnets) without removing the pumps from the network. Isolate Carol's workstation. Do *not* change pump configurations without biomedical engineering review — patient safety first.
- ❸ **Organizational failure:** “Temporary” solutions without a remediation deadline become permanent by default. The delayed VLAN rollout needed a tracked ticket with a forced completion date and executive visibility. Security debt in clinical environments requires formal risk acceptance, not informal deferral.

## Key Principle

In healthcare IT, “we’ll fix it later” is a patient safety statement. Temporary clinical network configurations require formal risk documentation.

## 11.3 Physical Security: Why It Belongs in a Networking Class

Network security is not purely digital. Physical access to hardware bypasses almost every logical control.

### Physical Access = Game Over

An attacker with physical access to a server can:

- Boot from USB and bypass disk encryption (if TPM is not configured correctly).
- Plug in a rogue network device and bypass all firewall rules.
- Shoulder-surf credentials, clone access badges, or install hardware keyloggers.

**Physical security is the first layer** of defense in depth. All your network controls are a fallback for when physical security fails.

### Hospital Physical Security Context

Hospitals are semi-public spaces operating 24/7, with sensitive equipment distributed throughout the building. Physical security must work at scale across hundreds of rooms, dozens of wiring closets, and a constantly changing population of staff, patients, and contractors.

# Locks and Physical Access Controls

Physical access to server rooms, wiring closets, and data centers must be controlled and logged.

## Types of Physical Locks

- **Keyed lock:** Simple, no audit trail. Lost keys are a permanent risk.
- **Badge/card reader:** Access logged by card ID and timestamp. Cards can be instantly revoked remotely.
- **PIN keypad:** Simple, but PINs can be shoulder-surfed and are rarely changed.
- **Biometric reader:** Fingerprint or iris. Very strong, but requires enrollment.
- **Mantrap (airlock):** Two doors in series — only one can open at a time. Prevents tailgating entirely.

## The Tailgating Problem

**Tailgating** (piggybacking) is when an unauthorized person follows an authorized person through a secured door. One of the most common physical security failures.

Mitigations:

- Mantraps: only one person enters per badge swipe.
- Security awareness training — employees should challenge unfamiliar faces.
- Camera coverage of all entry points.



# Access Control in Healthcare Environments

Hospitals must balance open patient access with tight control over clinical and IT spaces.

| Area                        | Control Level       | Typical Mechanism                          |
|-----------------------------|---------------------|--------------------------------------------|
| Public lobby, waiting rooms | Open access         | None (CCTV only)                           |
| Patient care floors         | Controlled          | Badge reader on stairwells/elevators       |
| Nursing station             | Restricted          | Badge reader, workstation auto-lock        |
| Pharmacy                    | High restriction    | Badge + PIN, mantrap, 24hr camera          |
| Server room / data closet   | Highest restriction | Badge + biometric, mantrap, no shared keys |
| Network wiring closets      | Often overlooked!   | Should have keyed lock + tamper alarm      |

## The Forgotten Wiring Closet

Wiring closets are scattered throughout hospital floors and may only have a basic keyed lock. A rogue device plugged into an unlocked closet's patch panel can bypass every logical network control. Physical lock + tamper detection is essential.

# Security Cameras and Surveillance

Cameras and access logs create an audit trail for physical security events.

## IP Camera Basics

Modern security cameras are IP devices — computers on your network.

- **Placement:** Cover all entry/exit points, server rooms, wiring closets. Blind spots are intentional targets.
- **Retention:** Store footage on a separate, restricted segment. Typically 30–90 days for incident response.
- **Hardening:** Cameras have default credentials and must be on a dedicated VLAN — treat them like any IoT device.
- **Tamper detection:** Alert if view is blocked or camera is physically moved.

## Cameras Are IoT Devices Too

Compromised cameras have been used to:

- Spy on facilities and plan intrusions.
- Serve as pivot points into internal networks.
- Participate in DDoS botnets (the Mirai botnet used hundreds of thousands of cameras).

Put cameras on a dedicated surveillance VLAN with no route to clinical or administrative networks.

# Geofencing

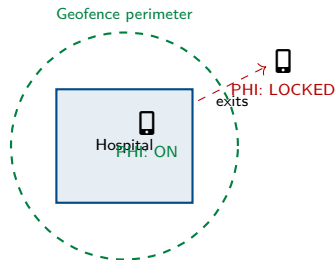
**Geofencing** uses location data to define a virtual geographic boundary and trigger policy actions when a device crosses that boundary.

## How Geofencing Works

Location is determined by GPS, Wi-Fi AP association, cellular network, or IP geolocation. When a device crosses the defined fence, the MDM (Mobile Device Management) system triggers automatic policy changes.

### Healthcare examples:

- A hospital tablet **auto-locks** when it leaves the building perimeter.
- A nurse's device **enables PHI access** only when on-campus.
- Remote VPN is **blocked** for logins from unusual countries.



Geofencing is a useful layer, not a complete control. GPS spoofing, VPNs, and unmanaged devices can all bypass it.

# Geofencing: Capabilities and Limitations

Geofencing is a useful policy tool, but it has important limitations.

## What Geofencing Can Do

- Automatically enforce location-based access policy without user action.
- Wipe or lock lost devices when they leave an approved area.
- Trigger alerts when corporate assets appear in unexpected locations.
- Restrict sensitive app functions (camera, export) outside designated areas.

## Geofencing Limitations

- **GPS spoofing:** Determined attackers can fake GPS coordinates.
- **IP geolocation is coarse:** VPNs and proxies trivially relocate an apparent IP address.
- **Requires MDM enrollment:** BYOD or unmanaged devices are invisible.
- **Indoor accuracy:** GPS does not work reliably inside large hospital buildings.

Geofencing is a useful layer, not a complete control.

# Case Study: Dr. House and the Open Server Room

## Scenario

Princeton-Plainsboro Teaching Hospital's IT department is stretched thin. The server room on the third floor holds the domain controllers, EHR database servers, and the VoIP call manager.

An intern named Thirteen notices the following during her first walkthrough:

- The server room door is propped open with a binder — housekeeping needs access to the mop closet next door and finds it easier than waiting for IT.
- The hallway camera is angled toward the nurses' station, covering little of the server room entrance.
- The badge log shows Dr. Gregory House badged in three times last Tuesday at 2:00 AM. House has no IT role and claims to know nothing about it.
- An unfamiliar network device is plugged into an open patch panel port behind a cabinet. It has no asset tag.

## Discussion Questions

- 1 Which physical security control most directly enabled the rogue device installation?
- 2 What should the immediate response be upon finding the unknown device?
- 3 What three process changes would prevent recurrence?

# Case Study Solution: Dr. House and the Open Server Room

## Recommended Response

- ❶ **Most direct enabler:** The propped-open server room door. The badge reader is completely circumvented when the door is held open. Even perfect badge logs are useless if the door is never actually closed. The misaligned camera means the unauthorized entry was not observed in real time.
- ❷ **Immediate response:** Do *not* simply unplug the device. Photograph it, capture the MAC address from switch port logs, then shut down the switch port before physically removing it. Treat it as a potential network tap. Escalate to incident response.
- ❸ **Three process changes:**
  - Door prop alarm: server room door open >30 seconds triggers an alert.
  - Realign the camera to cover the door frame directly.
  - Escort policy for non-IT personnel; housekeeping gets a separate mop closet key.

## Key Principle

Badge logs show who *used* the door — not who *entered*. Physical controls, camera coverage, and tailgating prevention must work together.

# Defense in Depth: Zones, IoT, and Physical Together

Each of the three domains in this module represents one layer of defense. No single layer is sufficient.

| Layer                    | What It Protects                      | Fails Against                         |
|--------------------------|---------------------------------------|---------------------------------------|
| Network zones / firewall | Lateral movement between segments     | Physical access; misconfiguration     |
| IoT segmentation         | Contains compromised devices          | Devices on wrong VLAN; default creds  |
| Physical locks / badge   | Prevents unauthorized hardware access | Tailgating; propped doors; lost cards |
| Cameras / audit logs     | Detects breaches after the fact       | Blind spots; footage tampering        |
| Geofencing               | Location-based policy enforcement     | GPS spoofing; unmanaged devices       |

## The Hospital as a Model

A well-secured hospital uses all layers at once: zones isolate clinical systems, IoT devices sit on dedicated VLANs, server rooms require badge and escort, and MDM geofencing locks tablets that leave the building. No single failure compromises everything.

# Zones and Perimeter Networks: Going Deeper

For students who want to understand perimeter network design at greater depth:

## Key Concepts to Explore Further

- **Zero Trust Architecture (ZTA):** NIST SP 800-207 argues that network zones are insufficient on their own — every request, even from an “internal” host, must be authenticated and authorized as if it came from the internet. Increasingly required in healthcare under HIPAA guidance.
- **Micro-segmentation:** SDN applies firewall policy at the individual workload level. Every server-to-server flow is explicitly permitted.
- **NIST SP 800-41:** Guidelines for firewalls and firewall policies.
- **CIS Controls:** The Center for Internet Security’s control framework, commonly used in hospital CISO programs.

## Career Path Note

Students heading into healthcare IT will likely work with a hybrid model: traditional perimeter zones for legacy systems and a Zero Trust initiative for new deployments. Both skill sets are needed simultaneously during multi-year migration programs.



# Embedded Systems and Zero Trust

IoT and embedded device security is one of the fastest-growing areas in healthcare IT.

## Healthcare-Specific IoT Frameworks

- **HIPAA Security Rule:** Requires covered entities to assess risks to all ePHI, including data transmitted by networked medical devices.
- **FDA Pre/Post-Market Guidance:** Requires device manufacturers to address cybersecurity throughout the device lifecycle, including patch planning.
- **MITRE ATT&CK for ICS:** Attack techniques targeting industrial and embedded systems — useful for threat modeling clinical networks.
- **H-ISAC:** Health Information Sharing and Analysis Center — shares threat intelligence for healthcare organizations.

## Zero Trust for Devices

Zero Trust applied to IoT means:

- Every device is enrolled and identified before being granted any network access.
- Devices get only the minimum permissions their function requires.
- Behavior is continuously monitored; anomalies (e.g., an infusion pump scanning the network) trigger automatic isolation.

This is the long-term direction for hospital biomedical device networks.

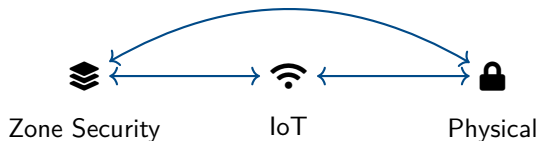
# Module 11 Summary I

- **Network security zones** divide infrastructure by trust level — internet, DMZ (semi-trusted), and internal (trusted) — so that a breach in one zone cannot freely spread to others.
- A **screened subnet (DMZ)** places public-facing services (web, email, VPN) between two firewalls, ensuring that a compromised DMZ host still faces a second defensive barrier before reaching internal systems.
- **Perimeter networks** host only services that require external reachability. Internal databases, EHR systems, and clinical devices must never be placed in or directly accessible from the DMZ.
- **IoT devices** — including medical equipment like infusion pumps, monitors, and imaging systems — often cannot be patched and must be isolated on dedicated VLANs with restrictive firewall policies as a compensating control.
- **Embedded and industrial systems** have lifecycles of 10–20 years, vendor constraints on patching, and no general-purpose operating system. Network segmentation and default-credential remediation are the primary security controls.

# Module 11 Summary II

- **Physical security** is the foundation: an attacker with physical access can bypass almost all logical controls. Server rooms and wiring closets require badge access, camera coverage, tamper alarms, and escort policies.
- **Geofencing** enforces location-based policy for mobile devices and remote access, but has limitations (GPS spoofing, indoor accuracy, unmanaged devices) and should be layered with other controls.
- All three domains — zones, IoT segmentation, and physical controls — form interlocking defense-in-depth layers. Failure in any one layer is survivable if the others hold; failure in all three simultaneously is a serious incident.

# Questions?



Next: Module 12 — Network Monitoring and Troubleshooting